

Privacy Impact Assessment (PIA): Patient Portal Mobile App

Organization: Company A (Government Entity)
Project: Mobile Patient Portal V2.0
Document ID: PIA-2024-005
Assessment Date: June 15, 2024
Classification: Confidential
Risk Rating: MEDIUM (After Controls)
Total Pages: 16

DOCUMENT CONTROL

Document Information

Attribute	Details
Document ID	PIA-2024-005
Title	Privacy Impact Assessment: Patient Portal Mobile A
Version	1.0 (Final)
Status	Approved
Owner	Privacy Office
Author	Sarah Al-Harbi (Chief Privacy Officer)
Assessment Method	PDPL-Compliant PIA Methodology
Assessment Period	May 1 - June 15, 2024

Version History

Version	Date	Author	Summary of Changes
0.1 (Draft)	2024-05-15	Sarah Al-Harbi	Initial draft and data flow mapping
0.5 (Review)	2024-06-01	Legal Department	Legal review and compliance validation
0.9 (Pre-Final)	2024-06-10	Dr. Yousef Al-Harbi	Medical Services review and clinical validation
1.0 (Final)	2024-06-15	Sarah Al-Harbi	Finalized for CDO and CEO approval

Approval

Name	Role	Signature	Date	Approval Decision
Sarah Al-Harbi	Chief Privacy Officer	[Signed]	2024-06-15	Approved with Conditions
Ahmed Al-Rashid	Chief Data Officer	[Signed]	2024-06-16	Approved
Dr. Abdullah Al-Ghamdi	Chief Executive Officer	[Signed]	2024-06-18	Approved

Approval Conditions:

- 1. All identified privacy controls must be implemented before production deployment
- 2. Mandatory security audit by external CISO before go-live
- 3. Monthly privacy monitoring reports for first 6 months post-launch

TABLE OF CONTENTS

- 1. EXECUTIVE SUMMARY 4
 - 1.1 Project Overview 4
 - 1.2 PIA Conclusion & Risk Rating 5
 - 1.3 Key Findings & Recommendations 6
- 2. PROJECT DESCRIPTION 7
 - 2.1 Business Objectives 7
 - 2.2 Key Features & Functionality 8
 - 2.3 Target Users 9
 - 2.4 Technology Stack 10
 - 2.5 Project Timeline 11
- 3. DATA FLOW ANALYSIS 12
 - 3.1 Data Collection 12
 - 3.2 Data Storage 14
 - 3.3 Data Processing 15
 - 3.4 Data Sharing & Third-Party Transfers 16
 - 3.5 Data Retention & Deletion 17
- 4. PERSONAL DATA INVENTORY 18
 - 4.1 Categories of Personal Data Processed 18
 - 4.2 Sensitive Personal Data (Special Categories) 19
 - 4.3 Data Minimization Analysis 20
- 5. PRIVACY RISK ASSESSMENT 21

5.1 Risk Assessment Methodology	21
5.2 Identified Privacy Risks	22
5.3 Risk Scoring Matrix	25
6. LEGAL & REGULATORY ANALYSIS	26
6.1 PDPL Compliance Requirements	26
6.2 Other Applicable Regulations	27
6.3 International Data Transfers	28
7. CONTROLS & MITIGATION MEASURES	29
7.1 Technical Controls	29
7.2 Organizational Controls	31
7.3 Contractual Controls	32
8. DATA SUBJECT RIGHTS	33
8.1 Right to Access	33
8.2 Right to Rectification	34
8.3 Right to Erasure	34
8.4 Right to Withdraw Consent	35
9. DPO OPINION & APPROVAL	36
9.1 Privacy Assessment Conclusion	36
9.2 Residual Risk Rating	37
9.3 Conditions for Approval	38
10. APPENDIX	39
10.1 Data Flow Diagrams	39
10.2 Third-Party Processors	40
10.3 Acronyms & Definitions	41

1. EXECUTIVE SUMMARY

1.1 Project Overview

Project Name: Mobile Patient Portal V2.0

Project Sponsor: Dr. Abdullah Al-Ghamdi (CEO)

Project Manager: Dr. Yousef Al-Harbi (Medical Services Director)

Project Description:

Company A is developing a next-generation mobile application (Patient Portal V2.0) to empower patients with secure, convenient access to their personal health information and healthcare services. The mobile app will be available on iOS and Android platforms and will replace the existing web-based patient portal (V1.0).

Key Capabilities:

- Health Records Access: View laboratory test results, radiology images, clinical notes, medications, and immunization records
- Appointment Management: Book, reschedule, and cancel appointments with physicians across Company A's 47 clinics and 5 hospitals
- Telemedicine: Conduct virtual video consultations with healthcare providers
- Medication Management: Receive push notifications for medication reminders and prescription refills
- Health Data Upload: Upload medical images (X-rays, photos of skin conditions, etc.) for physician review
- Secure Messaging: Communicate with healthcare providers via encrypted messaging
- Bill Payment: View and pay medical bills online

Target Launch Date: September 1, 2024

Expected User Base: 95,000 registered patients (current patient population)

1.2 PIA Conclusion & Risk Rating

Initial Risk Assessment (Before Controls)

Overall Privacy Risk Rating: HIGH

The Patient Portal V2.0 processes extensive sensitive personal data (medical records, biometric authentication) and introduces new privacy risks related to mobile device security, cloud storage, and third-party data sharing for analytics. Without adequate privacy controls, the project poses significant risks to patient privacy and PDPL compliance.

Final Risk Assessment (After Controls)

Overall Privacy Risk Rating: MEDIUM (Acceptable with Conditions)

Following the implementation of comprehensive technical, organizational, and contractual privacy controls (detailed in Section 7), the residual privacy risk has been reduced to an acceptable MEDIUM level. The project can proceed to production deployment subject to the following mandatory conditions:

1. Mandatory Conditions:

- All 18 identified privacy controls must be implemented and verified before production deployment
- External security audit by independent CISO (KPMG or equivalent) before go-live
- Mandatory employee training on patient data privacy for all support staff handling app inquiries
- Monthly privacy monitoring reports for first 6 months post-launch (submitted to CPO)

2. Approval Authority:

- Chief Privacy Officer: Approved with Conditions (Sarah Al-Harbi, June 15, 2024)
- Chief Data Officer: Approved (Ahmed Al-Rashid, June 16, 2024)
- Chief Executive Officer: Final Approval (Dr. Abdullah Al-Ghamdi, June 18, 2024)

1.3 Key Findings & Recommendations

Critical Findings

Finding #1: Biometric Data Processing (HIGH RISK - Mitigated)

- Issue: App uses FaceID/TouchID (biometric authentication) to secure access, processing highly sensitive biometric data
- PDPL Implication: Biometric data is classified as "Special Category" personal data under PDPL Article 4, requiring explicit consent and enhanced security
- Mitigation: Biometric data processed locally on device only (not transmitted to server); explicit opt-in consent obtained; alternative PIN authentication available
- Residual Risk: LOW (after controls)

Finding #2: Cloud Storage in Oracle Jeddah Region (MEDIUM RISK - Mitigated)

- Issue: Patient medical images and data stored in Oracle Cloud Infrastructure (Jeddah region)
- PDPL Implication: Data remains within Saudi Arabia (compliant with data localization preferences)
- Mitigation: Server-side encryption (AES-256), access controls, and Oracle Cloud security certifications (ISO 27001, SOC 2 Type II)
- Residual Risk: LOW (after controls)

Finding #3: Third-Party Analytics (Firebase/Google) (MEDIUM RISK - Mitigated)

- Issue: App shares device telemetry with Firebase (Google) for crash analytics and performance monitoring
- PDPL Implication: International data transfer to Google (U.S.) requires PDPL Article 28 compliance (adequate safeguards)
- Mitigation: Data anonymized (no Personal Data shared); Data Processing Agreement (DPA) signed with Google; Standard Contractual Clauses (SCCs) in place
- Residual Risk: LOW (after controls)

Key Recommendations

Recommendation #1: Implement Privacy-by-Design Principles

- Build privacy controls into app architecture from the ground up (not bolt-on)
- Default settings should maximize privacy (e.g., push notifications OFF by default)
- Mandatory privacy training for all app development team members

Recommendation #2: Transparent Privacy Notice

- Provide clear, concise privacy notice in Arabic and English before first use
- Explain what data is collected, why, and with whom it is shared
- Obtain granular consent for optional features (push notifications, location, camera access)

Recommendation #3: Ongoing Privacy Monitoring

- Implement monthly privacy audits for first 6 months post-launch
- Monitor for privacy incidents (unauthorized access, data leaks, user complaints)
- Conduct annual PIA refresh to reassess risks based on actual usage patterns

2. PROJECT DESCRIPTION

2.1 Business Objectives

Primary Objective: Improve patient engagement and satisfaction by providing convenient, secure access to personal health information via mobile devices

Secondary Objectives:

1. Reduce No-Show Rates: Enable patients to easily manage appointments and receive automated reminders (target: reduce no-shows from 8% to 5%)
2. Improve Medication Adherence: Push notifications for medication reminders to improve patient compliance with treatment plans
3. Enhance Patient Communication: Secure messaging with healthcare providers to reduce phone wait times and improve accessibility
4. Enable Telemedicine: Expand access to healthcare via video consultations, especially for remote patients
5. Paperless Operations: Reduce paper-based processes (appointment cards, printed lab results) through digital delivery

Success Metrics:

- 60% patient adoption rate within 12 months (57,000 of 95,000 patients)
- 4.0+ star rating on Apple App Store and Google Play Store
- <1% support ticket rate (fewer than 1% of users require help desk support)
- 30% reduction in call center volume for appointment booking and lab result inquiries

2.2 Key Features & Functionality

Core Features

1. Health Records Access

- Lab Results: View complete laboratory test results (blood work, urinalysis, COVID-19 tests, etc.)
- Radiology Images: View and download radiology images (X-rays, CT scans, MRI) in DICOM format
- Clinical Notes: Access physician clinical notes and visit summaries
- Medications: View current and historical prescriptions
- Immunization Records: Complete immunization history (especially important for pediatric patients)
- Vital Signs: Track blood pressure, weight, temperature, and other vital signs over time

2. Appointment Management

- Book Appointments: Search for available physicians by specialty, location, and availability; book appointments
- Reschedule/Cancel: Modify or cancel existing appointments (up to 24 hours before scheduled time)
- Appointment Reminders: Push notifications 24 hours and 1 hour before scheduled appointment
- Queue Status: Real-time clinic queue status to reduce wait times

3. Telemedicine (Video Consultations)

- Virtual Visits: Conduct secure video consultations with healthcare providers
- Screen Sharing: Share medical images or documents during video call
- Prescription Delivery: Physicians can prescribe medications during virtual visit (e-prescription sent to pharmacy)

4. Medication Management

- Medication List: View current medications with dosage and frequency
- Medication Reminders: Push notifications at prescribed medication times
- Refill Requests: Request prescription refills directly through app
- Drug Interaction Checker: Alerts if new medication interacts with existing medications

5. Medical Image Upload

- Camera Access: Take photos of skin conditions, wounds, or other visible symptoms
- Image Upload: Upload medical images or documents (e.g., referral letters, insurance cards)
- Physician Review: Uploaded images reviewed by physician before appointment

6. Secure Messaging

- Patient-Provider Messaging: Encrypted messaging with healthcare providers
- Message Notifications: Push notifications for new messages
- Message History: Archive of all communications

7. Bill Payment

- View Bills: Access itemized medical bills and invoices
- Online Payment: Pay bills via credit card, Apple Pay, or STC Pay
- Payment History: Download payment receipts and transaction history

Supporting Features

8. Biometric Authentication

- FaceID/TouchID: Quick, secure login using biometric authentication (iOS only)
- PIN Code: Alternative authentication method (4-6 digit PIN)
- Session Timeout: Automatic logout after 5 minutes of inactivity

9. Push Notifications

- Appointment Reminders: Automated reminders before scheduled appointments
- Lab Results Ready: Notification when new lab results are available
- Medication Reminders: Customizable medication reminders
- Provider Messages: Notification of new secure messages from healthcare providers

10. Multi-Language Support

- Arabic and English: Complete app interface available in both languages
- Right-to-Left (RTL) Support: Proper RTL layout for Arabic language

2.3 Target Users

Primary Users:

- Current Patients: 95,000 registered patients across 47 clinics and 5 hospitals
- Demographics: All age groups (pediatric to geriatric); 52% male, 48% female; 80% Saudi nationals, 20% expatriates

Secondary Users:

- Caregivers/Parents: Parents managing healthcare for minor children; caregivers for elderly or disabled patients

User Personas:

Persona 1: Ahmed Al-Rashid (Busy Professional)

- Age: 35, works long hours, visits clinic for annual checkup and occasional illness
- Needs: Quick appointment booking, lab result access, medication refills
- Pain Points: Difficulty finding time to call clinic during business hours

Persona 2: Fatima Al-Zahrani (Parent of 3 Children)

- Age: 42, manages healthcare for 3 children (ages 4, 7, 10)
- Needs: Manage appointments for multiple family members, immunization tracking, medication reminders
- Pain Points: Difficulty tracking appointment dates and vaccination schedules for 3 children

Persona 3: Dr. Yousef Al-Harbi (Elderly Patient)

- Age: 68, retired, manages chronic conditions (diabetes, hypertension), frequent clinic visits
- Needs: Easy access to medication list, appointment reminders, telemedicine for routine checkups
- Pain Points: Transportation challenges to clinic; difficulty remembering medication schedules

2.4 Technology Stack

Mobile App Development

Component	Technology	Details
iOS App	Swift 5.5, SwiftUI	Native iOS app for iPhone and iPad (iOS 14+)
Android App	Kotlin, Jetpack Compose	Native Android app for smartphones and tablets (An
Cross-Platform Framework	None (Native development)	Separate native apps for optimal performance and u

Backend Infrastructure

Component	Technology	Details
API Gateway	AWS API Gateway	RESTful API for mobile app-backend communication
Application Server	Node.js, Express.js	Backend logic and business rules
Database	Oracle 19c (existing EHR database)	Patient data stored in existing Epic EHR database
Cloud Storage	Oracle Cloud Storage (Jeddah region)	Medical images and documents
Authentication	OAuth 2.0, JWT	Token-based authentication

Security & Privacy

Component	Technology	Details
Encryption (Transit)	TLS 1.3	All data encrypted in transit using TLS 1.3
Encryption (Rest)	AES-256	All data encrypted at rest using AES-256
Biometric Auth	Apple FaceID/TouchID, Android BiometricPrompt	Local biometric authentication (data not transmitt
Certificate Pinning	Yes	Prevents man-in-the-middle attacks

Third-Party Services

Service	Provider	Purpose
Crash Analytics	Firebase Crashlytics (Google)	App crash reporting and diagnostics
Performance Monitoring	Firebase Performance (Google)	App performance metrics
Push Notifications	Firebase Cloud Messaging (Google)	Push notification delivery
Video Conferencing	Zoom Healthcare SDK	Telemedicine video consultations
Payment Gateway	HyperPay (Saudi payment processor)	Online payment processing

2.5 Project Timeline

Phase	Duration	Dates	Key Milestones
Planning & Design	2 months	Jan 1 - Feb 28, 2024	Requirements gathering, UI/UX design, PIA initiati
Development	3 months	Mar 1 - May 31, 2024	Mobile app development, API development, integrati
PIA & Security Review	1.5 months	May 1 - Jun 15, 2024	Privacy Impact Assessment, security audit, penetra
User Acceptance Testing	1 month	Jun 15 - Jul 15, 2024	Beta testing with 500 volunteer patients
Pre-Production Prep	1.5 months	Jul 15 - Aug 31, 2024	Staff training, app store submission, production s
Production Launch		Sep 1, 2024	Public release on Apple App Store and Google Play

3. DATA FLOW ANALYSIS

3.1 Data Collection

3.1.1 Data Collected Directly from Users

Data Element	Purpose	Collection Method	Required/Optional
National ID	User authentication and identity verification	User input during registration	Required
Mobile Phone Number	Account verification via SMS OTP	User input during registration	Required
Email Address	Account recovery and notifications	User input during registration	Required
Password	Account authentication	User input during registration	Required
Symptoms/Health Complaints	Pre-appointment questionnaire	User input (free-text)	Optional
Medical Images (Photos)	Clinical assessment by physician	Camera access (user captures photo)	Optional

3.1.2 Data Collected from Epic EHR Database

Data Element	Purpose	Source System
Patient Demographic Data	Display patient profile	Epic EHR PATIENT_MASTER
Laboratory Test Results	Display lab results to patient	Epic EHR LAB_RESULTS
Radiology Images	Display imaging studies to patient	Epic EHR PACS Integration
Medications	Display current and historical prescriptions	Epic EHR MEDICATION_ORDERS
Appointment History	Display past and future appointments	Epic EHR APPOINTMENTS
Clinical Notes	Display physician visit summaries	Epic EHR CLINICAL_NOTES
Immunization Records	Display vaccination history	Epic EHR IMMUNIZATIONS
Billing Statements	Display medical bills	Epic EHR BILLING

3.1.3 Data Collected from Device

Data Element	Purpose	Device Permission Required
Device ID (UUID)	Crash analytics and performance monitoring	None (automatic)
OS Version	Compatibility checks and crash analytics	None (automatic)
App Version	Compatibility checks and crash analytics	None (automatic)
Biometric Data (FaceID/TouchID)	User authentication	Biometric Permission
Camera Access	Capture medical images for upload	Camera Permission
Notification Permission	Push notifications for appointments and messages	Notification Permission
Location (Optional)	Find nearest clinic (future feature - NOT in V2.0)	NOT REQUESTED in V2.0

Privacy Note: Location permission explicitly removed from V2.0 to minimize data collection (privacy-by-design principle)

3.2 Data Storage

3.2.1 Server-Side Storage (Oracle Cloud - Jeddah Region)

Data Category	Storage Location	Encryption	Retention Period
User Account Data	Oracle Cloud DB (Jeddah)	AES-256 at rest	Account lifetime + 7 years after closure
Uploaded Medical Images	Oracle Cloud Object Storage (Jeddah)	AES-256 at rest	7 years (per medical records retention policy)
Secure Messages	Oracle Cloud DB (Jeddah)	AES-256 at rest	7 years
Push Notification Tokens	Firebase Cloud Messaging (Google)	Encrypted	Active device only

Data Localization: All patient health data stored within Saudi Arabia (Oracle Cloud Jeddah region) to comply with data localization best practices

3.2.2 Client-Side Storage (Mobile Device)

Data Category	Storage Location	Encryption	Retention Period
Authentication Token (JWT)	iOS Keychain / Android Keystore	Hardware-backed encryption	Session lifetime (24 hours)
Cached Lab Results	App sandbox (encrypted)	AES-256	30 days OR user logout (whichever is sooner)
Cached Images	App sandbox (encrypted)	AES-256	30 days OR user logout
User Preferences	App sandbox	No encryption needed (non-sensitive)	Until app uninstall

Automatic Cache Deletion: All cached personal data automatically deleted when user logs out or after 30 days of inactivity

3.2.3 Biometric Data Processing (FaceID/TouchID)

Critical Privacy Protection: Biometric data (facial features, fingerprints) is NEVER transmitted to Company A servers. Biometric authentication processed entirely on-device using Apple Secure Enclave / Android TEE (Trusted Execution Environment).

Process Flow:

1. User opts-in to biometric authentication during onboarding
2. Biometric data enrolled and stored in device secure enclave (Apple) or TEE (Android)
3. When user opens app, biometric verification performed locally on device
4. If successful, device returns authentication success flag to app (no biometric data transmitted)
5. App then authenticates with Company A backend using stored JWT token (not biometric data)

Result: Company A does NOT process or store biometric data - all processing occurs on user's device

3.3 Data Processing

Purpose Limitation & Legal Basis

Processing Activity	Purpose	Legal Basis (PDPL)
Display Health Records	Provide patient access to own medical records	Consent (PDPL Article 6)
Appointment Booking	Healthcare service delivery	Consent (PDPL Article 6)
Medication Reminders	Improve medication adherence (patient safety)	Consent (PDPL Article 6)
Push Notifications	Service notifications	Consent (PDPL Article 6) - opt-in required
Crash Analytics	App stability and bug fixing	Legitimate Interest (PDPL Article 6)
Telemedicine Video	Healthcare service delivery	Consent (PDPL Article 6) + Special Category Consent

3.4 Data Sharing & Third-Party Transfers

Third-Party Data Processors

Processor	Purpose	Data Shared	Location	Safeguards
Firebase (Google)	Crash analytics, performance monitoring	Device ID (UUID), OS version, app version	United States (Google Cloud)	DPA with Standard Contractual Clauses (SCCs)
Zoom Healthcare	Video conferencing for telemedicine	Video/audio stream during consultation	United States (Zoom Cloud)	BAA (HIPAA-equivalent), DPA signed; End-to-end encryption
HyperPay	Payment processing	Payment card data (tokenized - Not storing card number)	Canada	PCI-DSS Level 1 certified; Tokenization

International Data Transfer Safeguards:

- Firebase (Google): Standard Contractual Clauses (SCCs) per PDPL Article 28; Data anonymized (no Personal Data shared)
- Zoom Healthcare: Business Associate Agreement (BAA) signed; HIPAA-compliant (U.S. healthcare standard); End-to-end encryption

3.5 Data Retention & Deletion

Retention Schedule

Data Category	Retention Period	Deletion Method
Medical Records	7 years after last visit	Secure deletion (Oracle Cloud purge)
User Account Data	Account lifetime + 7 years	Secure deletion
Uploaded Images	7 years after upload	Secure deletion
Secure Messages	7 years	Secure deletion
Crash Analytics	90 days	Automatic deletion (Firebase)
Cached Data (Device)	30 days OR logout	Automatic deletion

Right to Erasure (PDPL Article 13)

Patient Request for Data Deletion:

1. Patient submits erasure request via app or written request to Privacy Office
2. Privacy Office verifies identity and confirms no legal retention requirement (e.g., active legal claim)
3. If approved, all data deleted within 30 days:
 - Account data deleted from Oracle Cloud
 - Cached data deleted from Firebase
 - Notification sent to patient confirming deletion

Exceptions to Erasure:

- Data required for legal compliance (e.g., tax records) retained per legal obligation
- Data subject to active legal hold (litigation, regulatory investigation) retained until hold lifted

4. PERSONAL DATA INVENTORY

4.1 Categories of Personal Data Processed

Data Category	Examples	Sensitivity	Volume
Identification Data	National ID, name, date of birth, gender	Medium	95,000 patients
Contact Data	Phone number, email address, home address	Low	95,000 patients
Authentication Data	Password (hashed), biometric reference	High	95,000 patients
Medical History	Diagnoses, treatments, clinical notes	Very High	95,000 patients
Laboratory Results	Blood tests, urinalysis, COVID-19 tests	Very High	820,000 test results
Radiology Images	X-rays, CT scans, MRI	Very High	1.2M images
Medications	Prescriptions, dosages, refill history	Very High	284,000 prescriptions
Appointment Data	Appointment dates, physician names, visit reasons	High	285,000 appointments
Financial Data	Medical bills, payment history	Medium	95,000 patients
Communications	Secure messages with providers	High	~50,000 messages/year
Device Data	Device ID, OS version, app version	Low	95,000 devices (estimate)

4.2 Sensitive Personal Data (Special Categories)

PDPL Article 4: Special Categories of Personal Data

The following "Special Categories" of personal data (requiring explicit consent and enhanced protection) are processed:

Special Category	Examples	Processing Justification	Consent Mechanism
Health Data	Medical diagnoses, lab results, prescriptions	Healthcare service delivery	Explicit opt-in consent obtained during app register
Biometric Data	FaceID facial features, TouchID fingerprints	User authentication (security)	Optional (alternative PIN available); Processed on device

Enhanced Protections for Special Categories:

- Explicit Consent: Separate, granular consent for health data processing (not bundled with general terms)
- Encryption: AES-256 encryption at rest and TLS 1.3 in transit
- Access Controls: Role-based access control (RBAC) - only authorized healthcare providers can access
- Audit Logging: All access to health data logged for security monitoring

4.3 Data Minimization Analysis

PDPL Article 3: Data Minimization Principle

The app was designed to minimize data collection:

Feature	Original Design	Data Minimization Change	Justification
Location Tracking	Requested location permission to show nearby clinics	REMOVED - Location permission not requested	Not essential for core functionality; can search by zip code
Contact List Access	Requested contact list to add emergency contacts	REMOVED - Manual entry only	Contact list access too broad; manual entry sufficient
Photo Library Access	Requested full photo library access for medical history uploads	LIMITED - Camera-only access	Limit to camera capture only (no access to existing photos)

Result: App requests minimal device permissions (Camera, Notifications, Biometric) - all optional except authentication

5. PRIVACY RISK ASSESSMENT

5.1 Risk Assessment Methodology

Risk Scoring Formula: Risk Level = Impact × Likelihood

Impact Scale (1-5):

- 1 (Negligible): No impact on patient privacy
- 2 (Minor): Minor inconvenience to patient
- 3 (Moderate): Moderate privacy concern; limited data exposure
- 4 (Major): Significant privacy breach; sensitive data exposed
- 5 (Catastrophic): Massive privacy breach; severe harm to patients (identity theft, discrimination)

Likelihood Scale (1-5):

- 1 (Rare): <1% chance of occurring
- 2 (Unlikely): 1-10% chance
- 3 (Possible): 10-50% chance
- 4 (Likely): 50-90% chance
- 5 (Almost Certain): >90% chance

Risk Matrix:

Impact	Likelihood 1	Likelihood 2	Likelihood 3	Likelihood 4	Likelihood 5
5 (Catastrophic)	MEDIUM	HIGH	HIGH	CRITICAL	CRITICAL
4 (Major)	LOW	MEDIUM	HIGH	HIGH	CRITICAL
3 (Moderate)	LOW	LOW	MEDIUM	MEDIUM	HIGH
2 (Minor)	LOW	LOW	LOW	LOW	MEDIUM
1 (Negligible)	LOW	LOW	LOW	LOW	LOW

5.2 Identified Privacy Risks

Risk #1: Unauthorized Family Member Access

Risk Description:

Patient leaves mobile device unlocked; family member picks up device and accesses sensitive health information (e.g., HIV test results, mental health records, pregnancy status)

Impact: 4 (Major) - Serious privacy breach; potential for family conflict, stigma, or discrimination

Likelihood (Before Controls): 4 (Likely) - Common scenario: patients often leave devices unlocked

Risk Score (Before Controls): $4 \times 4 = 16$ (HIGH RISK)

Controls & Mitigation:

1. Mandatory Re-Authentication: App requires FaceID/PIN every time it is opened (no persistent session for health data)
2. Auto-Logout: App automatically logs out after 5 minutes of inactivity
3. Privacy Screen Option: User can enable "privacy screen" to blur sensitive content until face/PIN verified
4. User Education: In-app privacy tips educating users to secure their devices

Likelihood (After Controls): 2 (Unlikely) - Controls significantly reduce risk

Residual Risk Score: $4 \times 2 = 8$ (MEDIUM RISK - Acceptable)

Risk #2: Cloud Storage Misconfiguration (Data Leak)

Risk Description:

Oracle Cloud Object Storage bucket misconfigured as "public" instead of "private", exposing patient medical images to internet

Impact: 5 (Catastrophic) - Massive privacy breach; thousands of patient images exposed; regulatory fines; reputational damage

Likelihood (Before Controls): 2 (Unlikely) - Requires configuration error, but has occurred at other organizations

Risk Score (Before Controls): $5 \times 2 = 10$ (HIGH RISK)

Controls & Mitigation:

1. Default Private: All Oracle Cloud Storage buckets configured as private by default (require explicit authentication)
2. Access Control Lists: Strict ACLs limit access to authorized backend services only
3. Cloud Security Monitoring: Oracle Cloud Guard monitors for misconfigurations (automated alerts)
4. Security Audits: Quarterly penetration testing and security audits by external CISO
5. Least Privilege: Backend services use minimal IAM permissions (principle of least privilege)

Likelihood (After Controls): 1 (Rare) - Multiple layers of protection

Residual Risk Score: $5 \times 1 = 5$ (LOW RISK - Acceptable)

Risk #3: Excessive Data Collection (Location Tracking)

Risk Description:

App requests "Location" permission without clear justification; location data could be used for patient tracking or sold to third parties

Impact: 3 (Moderate) - Privacy concern; location data reveals sensitive patterns (e.g., frequent visits to HIV clinic)

Likelihood (Before Controls): 5 (Almost Certain) - Many apps request excessive permissions

Risk Score (Before Controls): $3 \times 5 = 15$ (HIGH RISK)

Controls & Mitigation:

1. Permission Removed: Location permission explicitly removed from app manifest (not requested)
2. Privacy-by-Design: App architecture redesigned to avoid location dependency (search clinics by city name instead)
3. Minimal Permissions: Only essential permissions requested (Camera, Notifications, Biometric - all optional)

Likelihood (After Controls): 0 (Eliminated) - Risk eliminated through design change

Residual Risk Score: 0 (NO RISK)

Risk #4: Third-Party Analytics Data Sharing (Firebase/Google)

Risk Description:

App shares patient data with Firebase (Google) for crash analytics; Google could use data for advertising or other purposes

Impact: 3 (Moderate) - Privacy concern if Personal Data shared; potential PDPL violation

Likelihood (Before Controls): 3 (Possible) - Common practice to share analytics data

Risk Score (Before Controls): $3 \times 3 = 9$ (MEDIUM RISK)

Controls & Mitigation:

1. Data Anonymization: Only anonymous technical data shared with Firebase (Device ID as UUID, OS version, app version - NO Personal Data)
2. Data Processing Agreement: DPA signed with Google Firebase including Standard Contractual Clauses (SCCs)
3. Limited Purpose: Firebase data use restricted to crash analytics and performance monitoring only (no advertising)
4. User Transparency: Privacy notice clearly discloses Firebase usage and data shared

Likelihood (After Controls): 1 (Rare) - Data anonymized; contractual protections in place

Residual Risk Score: $3 \times 1 = 3$ (LOW RISK - Acceptable)

Risk #5: Man-in-the-Middle (MITM) Attack

Risk Description:

Attacker intercepts network traffic between mobile app and backend server, stealing patient health data

Impact: 5 (Catastrophic) - Massive data breach; all patient data transmitted could be exposed

Likelihood (Before Controls): 2 (Unlikely) - Requires technical sophistication, but possible on public Wi-Fi

Risk Score (Before Controls): $5 \times 2 = 10$ (HIGH RISK)

Controls & Mitigation:

1. TLS 1.3 Encryption: All API communication encrypted using TLS 1.3 (latest standard)
2. Certificate Pinning: App validates server SSL certificate against pinned certificate (prevents MITM)
3. No HTTP Fallback: App refuses to communicate over unencrypted HTTP (HTTPS only)

Likelihood (After Controls): 1 (Rare) - Strong encryption and certificate pinning prevent MITM

Residual Risk Score: $5 \times 1 = 5$ (LOW RISK - Acceptable)

Risk #6: Inadequate Access Controls (Employee Snooping)

Risk Description:

Company A employee (IT administrator, help desk staff) abuses access privileges to view patient records without authorization

Impact: 4 (Major) - Serious privacy breach; unauthorized access to sensitive health data

Likelihood (Before Controls): 3 (Possible) - Has occurred at other healthcare organizations

Risk Score (Before Controls): 4 × 3 = 12 (HIGH RISK)

Controls & Mitigation:

- 1. Role-Based Access Control (RBAC): Only authorized healthcare providers can access patient data (IT staff cannot)
- 2. Audit Logging: All data access logged with user ID, timestamp, and accessed records
- 3. Access Monitoring: Monthly audit of access logs to detect suspicious patterns
- 4. Employee Training: Mandatory privacy training for all staff handling patient data
- 5. Disciplinary Policy: Clear policy: unauthorized access = immediate termination

Likelihood (After Controls): 1 (Rare) - Strong access controls and monitoring deter abuse

Residual Risk Score: 4 × 1 = 4 (LOW RISK - Acceptable)

5.3 Risk Scoring Matrix

Summary of Privacy Risks

Risk ID	Risk Description	Impact	Likelihood (Before)	Risk (Before)	Likelihood (After)	Residual Risk	Status
R-001	Unauthorized family access	4	4	16 (HIGH)	2	8 (MEDIUM)	■ Acceptable
R-002	Cloud storage misconfiguration	5	2	10 (HIGH)	1	5 (LOW)	■ Acceptable
R-003	Excessive data collection (location)	3	5	15 (HIGH)	0	0 (NONE)	■ Eliminated
R-004	Third-party analytics sharing (Firebase)	3	3	9 (MEDIUM)	1	3 (LOW)	■ Acceptable
R-005	Man-in-the-middle attack	2	2	10 (HIGH)	1	5 (LOW)	■ Acceptable
R-006	Inadequate access controls (employee snooping)	2	6	12 (HIGH)	1	4 (LOW)	■ Acceptable

Overall Residual Privacy Risk: MEDIUM (Acceptable with Monitoring)

6. LEGAL & REGULATORY ANALYSIS

6.1 PDPL Compliance Requirements

Personal Data Protection Law (PDPL) - Royal Decree M/19, 2021

PDPL Requirement	Article	Compliance Status	Evidence
Lawfulness & Consent	Article 6	■ Compliant	Explicit opt-in consent obtained during app regist

Purpose Limitation	Article 3	■ Compliant	Data used only for healthcare service delivery (di
Data Minimization	Article 3	■ Compliant	Location permission removed; minimal data collecti
Special Category Data (Health)	Article 4	■ Compliant	Explicit consent + enhanced security (AES-256 encr
Special Category Data (Biometric)	Article 4	■ Compliant	Processed on-device only (not transmitted to serve
Data Security	Article 15	■ Compliant	TLS 1.3, AES-256, certificate pinning, RBAC, audit
International Data Transfer	Article 28	■ Compliant	SCCs with Firebase; BAA with Zoom; Data localizati
Data Subject Rights	Articles 11-14	■ Compliant	App provides access, rectification, erasure, withd
Privacy Notice	Article 7	■ Compliant	Clear, concise privacy notice in Arabic and Englis
Data Breach Notification	Article 26	■ Compliant	Incident response plan; 72-hour notification to SD

6.2 Other Applicable Regulations

National Cybersecurity Authority (NCA) - Essential Cybersecurity Controls (ECC)

Control Domain	Compliance Status	Evidence
Access Control	■ Compliant	RBAC, MFA (biometric/PIN), session timeout
Encryption	■ Compliant	TLS 1.3, AES-256, certificate pinning
Logging & Monitoring	■ Compliant	Comprehensive audit logging, monthly access review
Incident Response	■ Compliant	Incident response plan, 72-hour notification

6.3 International Data Transfers

Transfers Outside Saudi Arabia:

Processor	Country	Safeguard	Compliance Mechanism
Firebase (Google)	United States	Standard Contractual Clauses (SCCs)	PDPL Article 28
Zoom Healthcare	United States	Business Associate Agreement (BAA) + SCCs	PDPL Article 28

Data Localization (Primary Storage):

- All patient health data stored in Oracle Cloud (Jeddah region, Saudi Arabia)
- International transfers limited to anonymized analytics and encrypted video streams

7. CONTROLS & MITIGATION MEASURES

7.1 Technical Controls

Control ID	Control Name	Description	Implementation Status
TC-001	TLS 1.3 Encryption	All API communication encrypted using TLS 1.3	■ Implemented
TC-002	AES-256 Encryption (Rest)	All data at rest encrypted using AES-256	■ Implemented
TC-003	Certificate Pinning	App validates server SSL certificate to prevent MITM	■ Implemented
TC-004	Biometric Authentication	FaceID/TouchID for quick, secure authentication	■ Implemented
TC-005	Auto-Logout	App logs out after 5 minutes of inactivity	■ Implemented
TC-006	Role-Based Access Control (RBAC)	Only authorized healthcare providers can access data	■ Implemented
TC-007	Audit Logging	All data access logged with user ID, timestamp	■ Implemented
TC-008	Data Anonymization (Firebase)	Device ID anonymized before sharing with Firebase	■ Implemented
TC-009	Secure Storage (Keychain/Keystore)	Authentication tokens stored in hardware-backed secure storage	■ Implemented
TC-010	Input Validation	All user inputs validated to prevent injection attacks	■ Implemented

7.2 Organizational Controls

Control ID	Control Name	Description	Implementation Status
OC-001	Privacy Training	Mandatory privacy training for all staff handling data	■ Scheduled (Aug 2024)
OC-002	Access Reviews	Monthly review of access logs to detect anomalies	■ Scheduled (post-launch)
OC-003	Incident Response Plan	Documented incident response plan for data breaches	■ Implemented
OC-004	Data Retention Policy	Documented retention schedule and deletion process	■ Implemented
OC-005	Third-Party Risk Assessment	Privacy assessment of all third-party processors	■ Completed

7.3 Contractual Controls

Control ID	Control Name	Description	Implementation Status
CC-001	Data Processing Agreement (Firebase)	DPA with Google Firebase including SCCs	■ Signed
CC-002	Business Associate Agreement (Zoom)	BAA with Zoom Healthcare for HIPAA compliance	■ Signed
CC-003	Payment Processor Agreement (Stripe)	PCI-DSS compliance agreement with Stripe	■ Signed

8. DATA SUBJECT RIGHTS

8.1 Right to Access (PDPL Article 11)

Implementation: In-app "My Data" section allows patients to download complete copy of their personal data in JSON format

8.2 Right to Rectification (PDPL Article 12)

Implementation: Patients can update contact information directly in app; Medical data corrections require physician approval

8.3 Right to Erasure (PDPL Article 13)

Implementation: "Delete My Account" button in app settings; Data deleted within 30 days (subject to legal retention requirements)

8.4 Right to Withdraw Consent (PDPL Article 10)

Implementation: Patients can withdraw consent for push notifications, telemedicine, or data sharing in app settings; Account deletion = complete consent withdrawal

9. DPO OPINION & APPROVAL

9.1 Privacy Assessment Conclusion

Chief Privacy Officer Opinion:

Based on comprehensive privacy impact assessment conducted May 1 - June 15, 2024, I conclude that the Mobile Patient Portal V2.0 project demonstrates acceptable privacy risk subject to the implementation of all 18 identified privacy controls.

Key Strengths:

- Privacy-by-design approach (location tracking eliminated)
- Biometric data processed on-device only (not transmitted to servers)
- Strong encryption (TLS 1.3, AES-256)
- Data localization (Oracle Cloud Jeddah region)
- Comprehensive audit logging and access controls

Remaining Concerns:

- Third-party data sharing with Firebase (Google) requires ongoing monitoring to ensure data remains anonymized

- Employee access controls require monthly audits to prevent unauthorized access
- User education critical - patients must secure their devices to prevent family member access

9.2 Residual Risk Rating

Overall Residual Privacy Risk: MEDIUM (Acceptable)

All identified HIGH risks have been mitigated to LOW or MEDIUM levels through comprehensive technical, organizational, and contractual controls.

9.3 Conditions for Approval

APPROVED WITH CONDITIONS:

The Mobile Patient Portal V2.0 project is approved for production deployment subject to the following mandatory conditions:

1. All 18 privacy controls must be implemented and verified before production deployment (TC-001 through CC-003)
2. External security audit by independent CISO (KPMG or equivalent) before go-live (scheduled August 2024)
3. Mandatory privacy training for all customer support staff handling app-related inquiries (August 2024)
4. Monthly privacy monitoring reports for first 6 months post-launch (submitted to CPO)
5. Annual PIA refresh to reassess privacy risks based on actual usage patterns

Signature:

Sarah Al-Harbi
Chief Privacy Officer
Company A

Date: June 15, 2024

END OF PIA REPORT

Company A - Confidential

Document ID: PIA-2024-005

Version 1.0 (Final)

Date: June 15, 2024